CRISC Exam - Domain 4: Technology and Security

Hard Questions with Explanations

Compiled from ISACA CRISC QAE

October 19, 2026

Outline

1. Security Concepts: CIA, IAAA & Encryption
2. Networking, Access & Architecture
3. System Development, Data & Resilience
4. Emerging Technology, Privacy & New Risk

Q1: Resilient Business Processes

Question

Which business requirement BEST relates to the need for resilient business and information systems processes?

A. Effectiveness
B. Confidentiality
C. Integrity
D. Availability

Q1: Explanation

Correct Answer: D

Availability relates to information being available when required by the business process now and in the future. Resilience is the ability to provide and maintain an acceptable level of service during disasters or when facing operational challenges.

Option Analysis

- **A - Incorrect:** Effectiveness deals with information being relevant and delivered timely
- **B - Incorrect:** Confidentiality deals with protection from unauthorized disclosure
- **C - Incorrect:** Integrity relates to accuracy and completeness
- **D - Correct:** Availability is directly linked to resilience

Q2: Weather Forecast System Priority

Question

An information system that processes weather forecasts for public consumption is MOST likely to place its highest priority on:

A. Nonrepudiation
B. Confidentiality
C. Integrity
D. Availability

Q2: Explanation

Correct Answer: C

A system that delivers weather forecasts is likely to place its highest priority on the integrity of the data. The risk practitioner should keep in mind that whether a forecast turns out to be accurate in its prediction is distinct from whether the data was accurately represented.

Option Analysis

- **A - Incorrect:** Nonrepudiation is unlikely to be important for weather forecasts
- **B - Incorrect:** Keeping data confidential would be at odds with public use
- **C - Correct:** Integrity of data is paramount
- **D - Incorrect:** Availability is important but integrity is higher priority

Q3: Confidentiality Breach

Question

Which is an example of a breach of confidentiality?

- A Data being modified by unauthorized user
- B Data being unavailable when needed
- C Data being disclosed to unauthorized recipient
- D Data being destroyed

Q3: Explanation

Correct Answer: C

A breach of confidentiality means the improper disclosure of information to a recipient not authorized access by the information owner.

Option Analysis

- **A - Incorrect:** This is a breach of integrity
- **B - Incorrect:** This is a breach of availability
- **C - Correct:** Unauthorized disclosure is confidentiality breach
- **D - Incorrect:** This is a breach of integrity/availability

Q4: CIA Triad Trade-off

Question

Increasing confidentiality typically:

A. Increases availability
B. Decreases processing time
C. Increases processing time and may reduce availability
D. Has no effect on availability

Q4: Explanation

Correct Answer: C

Increasing confidentiality typically increases processing time, which reduces availability. There are trade-offs between the three principles.

Option Analysis

- **A - Incorrect:** Usually decreases availability
- **B - Incorrect:** Usually increases processing time
- **C - Correct:** Trade-off between confidentiality and availability
- **D - Incorrect:** There is typically an effect

Q5: Best Control to Prevent Unauthorized Access

Question

BEST control to prevent unauthorized access to information is user:

A. Accountability
B. Authentication
C. Identification
D. Access rules

Q5: Explanation

Correct Answer: B

Authentication verifies the user's identity and the right to access information according to the access rules.

Option Analysis

- **A - Incorrect:** Accountability maps activity back to responsible party
- **B - Correct:** Authentication verifies identity
- **C - Incorrect:** Identification without authentication does not grant access
- **D - Incorrect:** Access rules without identification and authentication do not grant access

Q6: Controlling Access to Sensitive Information

Question

Which control BEST protects from unauthorized individuals gaining access to sensitive information?

A. Using a challenge response system
B. Forcing periodic password changes
C. Monitoring unsuccessful login attempts
D. Providing access on a need-to-know basis

Q6: Explanation

Correct Answer: D

Physical or logical system access should be assigned on a need-to-know basis (legitimate business requirements) and in ways that incorporate least privilege and segregation of duties.

Option Analysis

- **A - Incorrect:** Challenge response doesn't address access design
- **B - Incorrect:** Password changes don't guarantee appropriate access
- **C - Incorrect:** Monitoring doesn't address appropriate access rights
- **D - Correct:** Need-to-know basis is fundamental

Q7: Best Defense Against Phishing

Question

Which defense is BEST to use against phishing attacks?

A. Intrusion detection system
B. Spam filters
C. End-user awareness
D. Application hardening

Q7: Explanation

Correct Answer: C

Phishing attacks are a type of social engineering attack and are best defended by end-user awareness training.

Option Analysis

- **A - Incorrect:** IDS doesn't protect against phishing
- **B - Incorrect:** Spam filters are not as effective as user awareness
- **C - Correct:** User awareness is the best defense
- **D - Incorrect:** Application hardening doesn't protect against phishing

Q8: Symmetric Encryption

Question

Symmetric encryption uses:

A. Two mathematically related keys
B. The same secret key for encryption and decryption
C. Public and private key pairs
D. Digital certificates

Q8: Explanation

Correct Answer: B

Symmetric key cryptography occurs when an encryption algorithm uses the same secret key to encrypt the plaintext into ciphertext and to decrypt the ciphertext back into plaintext.

Option Analysis

- **A - Incorrect:** This is asymmetric encryption
- **B - Correct:** Same key for both operations
- **C - Incorrect:** This is asymmetric encryption
- **D - Incorrect:** Certificates are for identity verification

Q9: Digital Signature

Question

A digital signature provides:

A. Confidentiality only
B. Integrity and nonrepudiation
C. Availability only
D. Authentication only

Q9: Explanation

Correct Answer: B

A digital signature combines a hash function with asymmetric encryption to verify the author's identity. It provides integrity (message not changed) and nonrepudiation (sender cannot deny sending).

Option Analysis

- **A - Incorrect:** Does not provide confidentiality on its own
- **B - Correct:** Provides integrity and nonrepudiation
- **C - Incorrect:** Not related to availability
- **D - Incorrect:** Provides more than authentication

Q10: Asymmetric Encryption Advantage

Question

Asymmetric encryption's main advantage over symmetric is:

A. Faster processing speed
B. Easier key management for secure exchange
C. Lower computational requirements
D. Simpler implementation

Q10: Explanation

Correct Answer: B

Asymmetric algorithms overcome the weakness of scalability of symmetric key cryptography by allowing secure key exchange. The public key can be freely distributed, making key management easier.

Option Analysis

- **A - Incorrect:** Asymmetric is slower
- **B - Correct:** Easier key management
- **C - Incorrect:** Higher computational requirements
- **D - Incorrect:** More complex implementation

Q11: Control to Reduce Impact of Compromised Admin Account

Question

Which control can reduce potential impact of malicious hacker who gains access to administrator account?

A. Multifactor authentication
B. Audit logging
C. Least privilege
D. Password policy

Q11: Explanation

Correct Answer: C

Least privilege can reduce the impact of a compromised account within the scope of its intended use and limit impact to the enterprise as a whole, without restricting the performance of employees in administrative roles.

Option Analysis

- **A - Incorrect:** Control has already been bypassed
- **B - Incorrect:** Audit logging is lagging indicator
- **C - Correct:** Least privilege limits scope of damage
- **D - Incorrect:** Password changes may not be frequent enough

Q12: Firewall Compliance Assurance

Question

Which provides BEST assurance that a firewall is configured in compliance with enterprise's security policy?

A. Reviewing actual procedures
B. Interviewing firewall administrator
C. Reviewing parameter settings
D. Reviewing log file for recent attacks

Q12: Explanation

Correct Answer: C

A review of the parameter settings provides a good basis for comparison of the actual configuration to the security policy and reliable audit evidence documentation.

Option Analysis

- **A - Incorrect:** Procedures show how it should be managed, not compliance
- **B - Incorrect:** Interview provides overview, not confirmation
- **C - Correct:** Parameter settings show actual configuration
- **D - Incorrect:** Log review shows logging is enabled, not configuration

Q13: Firewall Deviation Detection

Question

Which activity should a risk professional perform to determine whether firewall deployments are deviating from security policy?

- A Review firewall parameter settings
- B Review firewall intrusion prevention system logs
- C Review firewall hardening procedures
- D Analyze firewall log file for recent attacks

Q13: Explanation

Correct Answer: A

Firewall parameter settings will tie in with the configurations linked to the governing security policy. If the parameter settings differ from what policy states or requires, then there is a deviation.

Option Analysis

- **A - Correct:** Parameters show compliance with policy
- **B - Incorrect:** IPS logs show blocked packets, not configuration
- **C - Incorrect:** Hardening procedures show what was expected, not actual
- **D - Incorrect:** Attacks may not be covered in security policy

Q14: Best Defense Against External Network Attack

Question

Which is BEST way to ensure corporate network is adequately secured against external attack?

A. Use intrusion detection system
B. Establish minimum security baselines
C. Implement vendor recommended settings
D. Perform periodic penetration testing

Q14: Explanation

Correct Answer: D

Penetration testing is the best way to ensure that perimeter security is adequate.

Option Analysis

- **A - Incorrect:** IDS detects but doesn't confirm security
- **B - Incorrect:** Baselines are beneficial but not sufficient
- **C - Incorrect:** Vendor settings are beneficial but not sufficient
- **D - Correct:** Penetration testing provides highest assurance

Q15: Penetration Test Preparation

Question

Which should be in place before a black box penetration test begins?

A. Clearly stated definition of scope
B. Previous test results
C. Proper communication and awareness training
D. Incident response plan

Q15: Explanation

Correct Answer: A

A clearly stated definition of scope ensures a proper understanding of risk and success criteria.

Option Analysis

- **A - Correct:** Scope definition is essential
- **B - Incorrect:** Previous results may help define scope
- **C - Incorrect:** Communication/training not necessary
- **D - Incorrect:** IR plan not necessary

Q16: Cloud Deployment for Collaborative Research

Question

Which cloud computing deployment model is MOST appropriate for collaborative research program between universities?

A. Private cloud
B. Community cloud
C. Public cloud
D. Hybrid cloud

Q16: Explanation

Correct Answer: B

A community cloud deployment model is appropriate because it is shared between several enterprises and supports a specific community that has a common mission or interest.

Option Analysis

- **A - Incorrect:** Private cloud is for single enterprise
- **B - Correct:** Community cloud is for shared mission
- **C - Incorrect:** Public cloud is for general public
- **D - Incorrect:** Hybrid is combination

Q17: Highest Tolerance for Public Cloud

Question

Senior management will MOST likely have highest tolerance for moving which to public cloud?

A. Credit-card processing
B. Research and development
C. Legacy financial system
D. Corporate email system

Q17: Explanation

Correct Answer: D

Consideration for moving processes and information to the cloud should include the criticality, complexity and classification of the data. Of the options offered, the corporate email system has the least competitive distinction, complexity, and sensitive/highly classified information.

Option Analysis

- **A - Incorrect:** Credit-card processing is high security
- **B - Incorrect:** R&D contains confidential proprietary information
- **C - Incorrect:** Legacy financial system is sensitive and complex
- **D - Correct:** Email has least competitive distinction

Q18: Cloud Provider Greatest Risk

Question

Which poses GREATEST risk to enterprise that recently engaged services of cloud provider?

A. Cloud provider's facility is in same vicinity as subscriber
B. Service level agreement is ambiguous
C. References from other customers were not obtained
D. Auditing vendor requires dependence on third-party audit firm

Q18: Explanation

Correct Answer: B

If the service level agreement is ambiguous, it will be difficult to determine whether the provider complies.

Option Analysis

- **A - Incorrect:** No direct impact if continuity plan is adequate
- **B - Correct:** Ambiguous SLA makes compliance verification difficult
- **C - Incorrect:** References are important but can't assure delivery
- **D - Incorrect:** Inability to audit is less than desirable but allowed under SSAE 18

Q19: Thin Client Interface Cloud Model

Question

Which cloud service model provides applications accessible from client devices through a thin client interface (e.g., web browser)?

- A IaaS
- B PaaS
- C SaaS
- D DaaS

Q19: Explanation

Correct Answer: C

SaaS (Software as a Service) offers the capability to use the provider's applications running on cloud infrastructure, accessible through a thin client interface such as a web browser.

Option Analysis

- **A - Incorrect:** IaaS provides processing, storage, networks
- **B - Incorrect:** PaaS provides a platform for deploying customer-created apps
- **C - Correct:** SaaS provides provider's applications via thin client
- **D - Incorrect:** DaaS is not a standard cloud service model in this context

Q20: First Step When Designing IS Controls

Question

Which should be considered FIRST when designing information system controls?

A. Organizational strategic plan
B. Existing IT environment
C. Present IT budget
D. IT strategic plan

Q20: Explanation

Correct Answer: A

Review of the enterprise's strategic plan is the first step in designing effective IS controls that would fit the enterprise's long-term plans.

Option Analysis

- **A - Correct:** Strategic plan is the starting point
- **B - Incorrect:** Useful but not the first task
- **C - Incorrect:** Budget is one component of strategic plan
- **D - Incorrect:** IT strategic plan exists to support enterprise's strategic plan

Q21: Business Process Review

Question

Which is the PRIMARY purpose of performing a business process review when responding to risk?

A. To ensure the correct solution is selected to integrate with the existing environment

B. To identify all possible risk in the enterprise

C. To replace the need for a risk assessment

D. To document the organizational hierarchy

Q21: Explanation

Correct Answer: A

When responding to risk, the organization should review its business processes to ensure that the correct solution is selected to integrate and work effectively with the existing environment or determine whether the environment should be reengineered.

Option Analysis

- **A - Correct:** Ensures correct solution integration
- **B - Incorrect:** Risk identification is a separate process
- **C - Incorrect:** It complements, not replaces, risk assessment
- **D - Incorrect:** Documenting hierarchy is not the primary purpose

Q22: Environments with Low RTO

Question

Environments with low recovery time objectives (RTOs) typically have:

A. Constant transaction logs
B. Highly available system architectures
C. Tape backups
D. Delayed replication

Q22: Explanation

Correct Answer: B

Environments with low RTOs typically have highly available system architectures (such as clustered servers), while those with low RPOs have highly available data architectures or constant transaction logs.

Option Analysis

- **A** - **Incorrect:** Constant transaction logs relate to low RPOs
- **B** - **Correct:** Low RTO needs highly available systems
- **C** - **Incorrect:** Tape backups relate to high RPOs
- **D** - **Incorrect:** Delayed replication relates to higher RPOs

Q23: RTO and MTD Relationship

Question

Which statement correctly describes the relationship between recovery time objective (RTO) and maximum tolerable downtime (MTD)?

A. RTO must be greater than MTD
B. RTO must be less than MTD
C. RTO and MTD must be equal
D. RTO is unrelated to MTD

Q23: Explanation

Correct Answer: B

RTO must be less than MTD. If RTO is greater than or equal to MTD, the business cannot recover before failure.

Option Analysis

- **A - Incorrect:** Would mean recovery takes longer than the business can survive
- **B - Correct:** Recovery must complete before maximum tolerable downtime
- **C - Incorrect:** Equal would leave no margin
- **D - Incorrect:** They are directly related

Q24: Data Classification Responsibility

Question

Who is MOST likely responsible for data classification?

A. Data user
B. Data owner
C. Data custodian
D. System administrator

Q24: Explanation

Correct Answer: B

The data owner is responsible for classifying data according to the enterprise's data classification scheme. The classification scheme then defines who is eligible to access the data and what controls are required.

Option Analysis

- **A - Incorrect:** Data user gains access based on business need
- **B - Correct:** Data owner classifies data
- **C - Incorrect:** Data custodian implements controls
- **D - Incorrect:** System administrator is a custodian

Q25: Data Custodian Responsibility

Question

Which role is responsible for implementing and maintaining the controls that protect data, such as backups and encryption?

A. Data owner
B. Data custodian
C. Data user
D. Data subject

Q25: Explanation

Correct Answer: B

The data custodian implements controls and maintains data, performing tasks such as backup, encryption and security patching on behalf of the data owner.

Option Analysis

- **A - Incorrect:** Data owner decides what happens to data
- **B - Correct:** Custodian protects and maintains data
- **C - Incorrect:** User uses data for business purposes
- **D - Incorrect:** Data subject is the individual the data is about

Q26: User Entitlement Changes

Question

Who is responsible for assigning user entitlement changes?

A. IT department
B. Data owner
C. System administrator
D. Data custodian

Q26: Explanation

Correct Answer: B

The data owner is responsible for assigning user entitlement changes. IT implements; the owner decides.

Option Analysis

- **A - Incorrect:** IT implements but does not decide
- **B - Correct:** Owner decides on entitlement changes
- **C - Incorrect:** Administrator implements, does not decide
- **D - Incorrect:** Custodian implements controls, does not decide access

Q27: Vulnerability from Weak Passwords

Question

Weak passwords and transmission over unprotected communication lines are examples of:

A. Vulnerabilities
B. Threats
C. Probabilities
D. Impacts

Q27: Explanation

Correct Answer: A

Vulnerabilities represent characteristics of information resources that may be exploited by a threat.

Option Analysis

- **A - Correct:** Weak passwords and unprotected transmission are vulnerabilities
- **B - Incorrect:** Threats are circumstances with potential to cause harm
- **C - Incorrect:** Probabilities represent likelihood of occurrence
- **D - Incorrect:** Impacts represent outcome of threat exploiting vulnerability

Q28: Lack of Adequate Controls

Question

A lack of adequate controls represents:

- (A) A vulnerability
- (B) An impact
- (C) An asset
- (D) A threat

Q28: Explanation

Correct Answer: A

Lack of adequate controls represents a vulnerability, exposing sensitive information and data to the risk of malicious damage, attack, or unauthorized access.

Option Analysis

- **A - Correct:** Vulnerability = lack of controls
- **B - Incorrect:** Impact is financial loss measure
- **C - Incorrect:** Assets have tangible/intangible value
- **D - Incorrect:** Threat is potential cause

Q29: Threat vs. Risk Misclassification

Question

Which of the following is an example of a threat that is often misclassified as a risk?

- A Data breach resulting in fines
- B Ransomware attack
- C Loss of customer trust
- D Regulatory penalty

Q29: Explanation

Correct Answer: B

A ransomware attack is a threat event. It becomes a risk only when combined with the probability of it occurring and the impact it would have on the organization. A common mistake is improperly categorizing threat events as "risks."

Option Analysis

- **A - Incorrect:** This describes an impact/consequence
- **B - Correct:** Ransomware is a threat until it impacts something important
- **C - Incorrect:** Loss of trust is an impact
- **D - Incorrect:** Regulatory penalty is an impact

Q30: Quantum Computing Impact

Question

The MOST critical concern related to quantum computing for all organizations is its impact on:

A. Job displacement
B. Applied cryptography
C. Supply chain vulnerabilities
D. Power generation sustainability

Q30: Explanation

Correct Answer: B

One of the most critical concerns, impactful to all organizations, is quantum computing's impact on applied cryptography. Encryption used to secure financial transactions, protect sensitive information and safeguard digital identities will effectively become obsolete once quantum computers become mainstream.

Option Analysis

- **A - Incorrect:** Job displacement is a concern but not the most universal
- **B - Correct:** Cryptography impact affects all organizations
- **C - Incorrect:** Supply chain is a concern but not the most critical
- **D - Incorrect:** Sustainability is a concern but not the most critical

Q31: Deepfake Social Engineering

Question

Which emerging technology poses a substantial challenge for organizations that authorize financial transfers based on verbal approval of an authority figure?

- A Big data analytics
- B Deepfake technology
- C Blockchain
- D Internet of Things

Q31: Explanation

Correct Answer: B

Deepfake technology can create convincing audio and video imitations of a person based on samples. This poses substantial challenges for organizations that authorize financial transfers, release data or carry out other sensitive tasks based on verbal or visual approval of an authority figure.

Option Analysis

- **A - Incorrect:** Big data analytics is not a deception technology
- **B - Correct:** Deepfakes enable convincing impersonation
- **C - Incorrect:** Blockchain is a ledger technology
- **D - Incorrect:** IoT is about connected devices

Q32: AI Risk Management

Question

Which of the following is an example of a nontechnical risk that enterprises may overlook when using AI solutions?

A. Software bugs
B. Biased or incorrect outputs impacting human rights and safety
C. Unpatched vulnerabilities
D. Network latency

Q32: Explanation

Correct Answer: B

AI presents numerous areas of nontechnical risk, which many enterprises may overlook—namely, ethical and environmental impacts of using AI solutions. Biased or incorrect outputs that directly impact human rights and safety can result in reputational and legal damage.

Option Analysis

- **A - Incorrect:** Software bugs are technical risk
- **B - Correct:** Ethical/bias impacts are nontechnical risk
- **C - Incorrect:** Unpatched vulnerabilities are technical risk
- **D - Incorrect:** Network latency is technical risk

Q33: Informed Consent

Question

Which privacy concept requires that data be collected, used and retained with the agreement of the individual, and that the individual be able to revoke that agreement?

- A Minimization
- B Purpose limitation
- C Informed consent
- D Destruction

Q33: Explanation

Correct Answer: C

Data subject to privacy regulations should be collected, used and retained with the informed consent of the subject. There may also need to be a process for revocation of consent.

Option Analysis

- **A - Incorrect:** Minimization is about collecting only what is needed
- **B - Incorrect:** Purpose limitation restricts use to the stated purpose
- **C - Correct:** Informed consent includes revocation rights
- **D - Incorrect:** Destruction is about eliminating data when no longer needed

Q34: Privacy Impact Assessment

Question

A privacy impact assessment (PIA) primarily accounts for the effects of a compromise on the:

A. Enterprise
B. Data subject
C. IT department
D. Regulator

Q34: Explanation

Correct Answer: B

Similar to a risk assessment, a PIA accounts for the effects of a compromise on the subject rather than impact to the enterprise.

Option Analysis

- **A - Incorrect:** Enterprise impact is the focus of risk assessment
- **B - Correct:** PIA focuses on harm to the individual
- **C - Incorrect:** IT department is not the focus
- **D - Incorrect:** Regulator is not the focus

Q35: Data Minimization

Question

Why is data minimization a key principle for managing privacy risk?

A. It reduces storage costs

B. It limits the potential impact of a data breach

C. It improves system performance

D. It simplifies backup procedures

Q35: Explanation

Correct Answer: B

Data is both an asset and a potential disaster for enterprises subject to strong privacy regulations should a data breach occur. Privacy is best assured when only data that is expressly needed and relevant for a particular purpose is collected, limiting the impact of a breach.

Option Analysis

- **A - Incorrect:** Cost reduction is a benefit but not the key privacy rationale
- **B - Correct:** Less data means less exposure in a breach
- **C - Incorrect:** Performance is a secondary benefit
- **D - Incorrect:** Backup simplification is a secondary benefit

Q36: What is a Risk Event?

Question

For something to be a risk event, it must involve three key factors. Which of the following correctly lists them?

A. Asset, control, audit
B. Threat event, probability, impact
C. Vulnerability, control, impact
D. Threat, asset, control

Q36: Explanation

Correct Answer: B

For something to be a risk event, it must involve three key factors: 1) a threat event, 2) probability (likelihood of the outcome), and 3) impact (magnitude of loss resulting from a threat exploiting a vulnerability).

Option Analysis

- **A - Incorrect:** Controls and audits are not key factors of a risk event
- **B - Correct:** Threat event, probability, impact
- **C - Incorrect:** A control is not a factor; vulnerability alone is not a risk event
- **D - Incorrect:** Control is not a key factor

Q37: Vulnerability Assessment vs. Penetration Test

Question

What is the key difference between a vulnerability assessment and a penetration test?

A. A vulnerability assessment is more expensive

B. A penetration test actively attempts to exploit vulnerabilities to determine if a breach is possible

C. A vulnerability assessment requires management approval

D. A penetration test only identifies known vulnerabilities

Q37: Explanation

Correct Answer: B

A vulnerability assessment identifies potential points of compromise. A penetration test simulates an adversary using intrusive methods in an attempt to circumvent controls and exploit potential vulnerabilities to achieve objectives.

Option Analysis

- **A - Incorrect:** Cost is not the key differentiator
- **B - Correct:** Penetration testing actively exploits
- **C - Incorrect:** Both require management approval
- **D - Incorrect:** Vulnerability scans identify known issues; pen tests find unknown

Q38: CVSS Metrics

Question

Which Common Vulnerability Scoring System (CVSS) metric group can be customized based on the vulnerability's impact within a specific organizational context?

- A Base metrics
- B Temporal metrics
- C Environmental metrics
- D Foundational metrics

Q38: Explanation

Correct Answer: C

Environmental metrics customize the score based on the vulnerability's impact within a specific organizational context. Base metrics define inherent characteristics, and temporal metrics reflect the current state of exploitability.

Option Analysis

- **A - Incorrect:** Base metrics are constant across environments
- **B - Incorrect:** Temporal metrics change over time but are not org-specific
- **C - Correct:** Environmental metrics are org-specific
- **D - Incorrect:** Foundational is not a CVSS metric group

Q39: Security Information and Event Management (SIEM)

Question

What is the primary function of a SIEM system?

A. To store backup data

B. To correlate data from multiple sources to identify security events

C. To manage user identities

D. To encrypt network traffic

Q39: Explanation

Correct Answer: B

SIEM systems are integrated data correlation tools that capture data from multiple sources and analyze system, application and network activity for possible security events.

Option Analysis

- **A - Incorrect:** Not for backup storage
- **B - Correct:** Correlation of multiple data sources
- **C - Incorrect:** Identity management is separate
- **D - Incorrect:** Not for traffic encryption

Q40: Endpoint Detection and Response (EDR)

Question

Unlike signature-based antivirus, Endpoint Detection and Response (EDR) is primarily designed to:

A. Detect known attack patterns

B. Be predictive by identifying threats designed to evade traditional defenses

C. Block all malware

D. Store endpoint logs indefinitely

Q40: Explanation

Correct Answer: B

EDR attempts to be predictive in nature, focusing on identifying threats and malware designed to evade traditional security defenses. It leverages cyberthreat intelligence and ML in conjunction with file analysis.

Option Analysis

- **A - Incorrect:** Signature-based AV detects known patterns
- **B - Correct:** EDR is predictive and finds evasive threats
- **C - Incorrect:** No control blocks all malware
- **D - Incorrect:** Log storage is a feature but not the primary purpose

Q41: Technology Refresh Risk

Question

Which is a risk consideration related to retaining legacy systems that are past their supported life?

A. Ability to patch/mitigate vulnerabilities may be limited
B. Lack of documentation
C. Vendor lock-in
D. All of the above

Q41: Explanation

Correct Answer: D

Risk considerations related to technology refresh include age of equipment, limited ability to patch/mitigate vulnerabilities, lack of documentation, limited expertise for maintenance, vendor lock-in, and availability of replacement parts.

Option Analysis

- **A** - **Incorrect:** A valid concern but not the only one
- **B** - **Incorrect:** A valid concern but not the only one
- **C** - **Incorrect:** A valid concern but not the only one
- **D** - **Correct:** All of these are valid legacy system risks

Q42: Zero Trust Architecture

Question

A zero trust architecture focuses on protecting resources and controlling access based on:

A. The network segment the resource is on
B. The user's identity, device posture and context
C. The physical location of the data center
D. The firewall rules at the perimeter

Q42: Explanation

Correct Answer: B

Zero trust moves defenses from static, network-based perimeters to focus on users, assets and resources. It requires real-time monitoring and granular visibility of user and application behavior attributes to make access decisions.

Option Analysis

- **A - Incorrect:** Zero trust does not rely on network segments
- **B - Correct:** Access is based on identity, device and context
- **C - Incorrect:** Physical location is not the primary control factor
- **D - Incorrect:** Perimeter firewalls are not the basis of zero trust

Domain 4 Key Takeaways

Essential Concepts

- CIA triad involves trade-offs; you can't maximize all three
- Authentication verifies identity; authorization determines permissions
- Digital signatures provide integrity and nonrepudiation
- Data owner classifies data; data custodian implements controls
- Penetration testing actively exploits vulnerabilities
- RTO must be less than MTD
- Zero trust focuses on users, assets and context, not network perimeters
- Emerging tech (AI, quantum, deepfakes) introduces new risk categories

Final Advice

Exam Preparation

Remember:

- Understand the *why* behind each concept
- Know the difference between similar terms (vulnerability vs. threat, IDS vs. IPS)
- Understand the risk management life cycle (Identify, Assess, Respond, Monitor)
- Practice scenario-based questions
- Use the ISACA mindset - choose the MOST appropriate answer

Good Luck on Your CRISC Exam!